

Permissions

권한과 신뢰 모델

Trusted vs Per-request, /tools 명령, 4-tier shell, 3-tier path

5 개 built-in tool, trust-all-tools 위험과 안전 사용 패턴

Choi, WooHyung

Prin. Solutions Architect

AWS Korea

whchoi@amazon.com



Agenda

Chapter 09, Permissions

01

권한 모델 개요

Trusted vs Per-request, 5 개 built-in tool

02

/tools 5 개 관리 명령

help, trust, untrust, trust-all, reset

03

Shell 명령 4-tier 신뢰

Full / Partial / Base / Entire Tool

04

Read / Write 3-tier 경로

Specific paths / Directory / Entire Tool

05

Default 동작과 권장 패턴

Read 기본 trusted, 환경별 권장 설정

06

trust-all 위험 분석

Production 금지, 위험 예시, 책임 소재

07

보안 베스트 프랙티스

Restricting access, AWS 권한, steering 활용

권한 모델 개요

TWO STATES, FIVE BUILT-IN TOOLS

PERMISSION MODEL

Kiro 의 권한 모델은 단순하며, 각 tool 은 두 가지 상태.

Trusted 는 확인 없이 사용 가능, Per-request 는 매번 사용자 승인 필요. built-in tool 이 있으며 각각 기본 trust 정책이 다름.

TWO STATES

두 가지 권한 상태

1. Trusted - 확인 없이 사용 가능
2. Per-request - 매번 승인 요청
3. /tools 로 현재 상태 조회
4. 세션 단위로 적용 - 종료 시 초기화

BUILT-IN TOOLS

기본 제공 tool

1. read - 파일 및 디렉토리 읽기
2. write - 파일 생성과 수정
3. shell - bash 명령 실행
4. aws - AWS CLI 호출

2 상태

Trusted, Per-request

4 종

Built-in tools

/tools

관리 명령 prefix

Per session

권한 적용 범위

/tools 관리 명령 5 종

VIEWING AND MANAGING PERMISSIONS

TOOLS COMMAND FAMILY

/tools 슬래시 명령은 5 개의 subcommand 로 권한을 관리.

현재 상태 조회, 개별 trust 와 untrust, 전체 trust, 모든 권한을 초기화하는 reset 까지 포함.

명령	설명
/tools	현재 모든 tool 의 권한 상태 표시
/tools trust <name>	특정 tool 을 세션 동안 trust 로 변경
/tools untrust <name>	Tool 을 per-request 로 되돌리기
/tools trust-all	모든 tool 을 즉시 trust, 사용 전 확인 경고
/tools reset	모든 runtime 권한 초기화, 기본값 복원

/tools

현재 상태 조회

trust

허용 전환

untrust

재확인 전환

reset

전체 초기화

Shell 명령 4-tier 신뢰

GRANULAR SHELL COMMAND TRUST

FOUR-TIER TRUST PICKER

Shell 명령 승인 시 4 단계 trust 계층 picker 가 표시. 가장 제한적인 Full command 부터 가장 광범위한 Entire Tool 까지.

예, `git pull --rebase` 를 trust 하면 4 가지 옵션이 나타남.

TIER 1- FULL

Exact command

정확히 이 명령만 허용.

예, `git pull --rebase`

만 trust.

가장 안전한 옵션.

TIER 2- PARTIAL

Partial command

Subcommand 와 임의 인자 허용.

예, `git pull *`. `git pull origin main` 등도 포함.

TIER 3- BASE

Base command

Base command 와 모든 인자 허용.

예, `git *`. 모든 git 관련 명령 trust.

TIER 4- ENTIRE

모든 shell 명령

Shell tool 전체 허용.

패턴은 *. 가장 광범위, 신중히 사용.

4 tier

Trust 계층 단계

allowedCommands

Agent 설정 키

Regex

내부 저장 형식

Picker

선택 UI 방식

Read / Write 3-tier 경로 신뢰

GRANULAR FILESYSTEM PATH TRUST

PATH TRUST PICKER

Read 와 write tool 도 현재 작업 디렉토리 외부 경로 접근 시 3 단계 picker 를 제공.

CWD 내부 경로는 picker 가 표시되지 않으며 read 의 경우 기본 trusted.

TIER 1- PATHS

Specific paths

정확히 요청된 파일 경로만 허용.

예, ~/.config/app/settings.json 1개 파일.

가장 제한적이고 안전.

TIER 2- DIRECTORY

Complete directory

포함 디렉토리의 모든 파일 허용.

예, ~/.config/app 디렉토리 전체.
관련 파일 일괄 허용에 적합.

TIER 3- ENTIRE

Entire Tool

Read 또는 write tool 전체 허용.

패턴은 *. 시스템 전체에서 작업 가능,
매우 광범위.

3 tier

경로 trust 계층

CWD

기본 trusted 범위

Outside

Picker 트리거 조건

Read

기본 trusted tool

Default 동작과 권장 패턴

DEFAULTS BY TOOL, RECOMMENDED USAGE

DEFAULT TRUST

기본 권한 상태

1. read - CWD 내부 trusted, 외부 per-request
2. write - 모든 경로 per-request
3. shell - 모든 명령 per-request
4. aws - 모든 호출 per-request

RECOMMENDED PATTERNS

환경별 권장 설정

1. 탐색 - `/tools trust read` 로 빠른 코드 읽기
2. 개발 - write 도 trust 로 파일 작업 가속
3. 민감 환경 - `/tools untrust shell` 로 명령 검토
4. 프로덕션 AWS - `/tools untrust aws` 로 변경 방지

read

유일하게 기본 trusted

CWD

기본 trust 범위

Dev

Trust 가속 권장

Prod

Untrust 보수 권장

trust-all-tools 위험 분석

WHY PRODUCTION IS A NO-GO

TRUST-ALL RISKS

/tools trust-all 과 --trust-all-tools 는 모든 권한 확인을 우회.

편리하지만 의도하지 않은 변경, AWS 리소스 변경, 데이터 손실, 보안 침해 위험을 크게 증가시킴. **Production**에서는 절대 사용 금지.

UNINTENDED

예상 외 시스템 변경

Clean up old files 요청이 중요
설정 파일을 삭제할 수 있음.

AWS

AWS 리소스 변경

Optimize my EC2 가 실행
중 인스턴스를 종료할 수 있음.

DATA LOSS

데이터 손실

Delete 와 overwrite 명령이
의도와 다르게 동작해 데이터
손실 가능.

SECURITY

보안 침해

Fix security issues 가 권한을
잘못 변경해 민감 데이터 노출
가능.

4 위험

주요 위험 카테고리

Prod 금지

운영 환경 사용 불가

User 책임

모든 동작에 대한

/tools reset

사용 후 복원 명령

보안 모범 사례

SAFE PERMISSION HYGIENE

RESTRICT

접근 제한

민감 환경에서 `/tools untrust read`로 파일 읽기도 매번 검토.
별도 dev 환경 사용 - 민감 파일은 프로젝트 외부 보관 권장.

AWS HYGIENE

AWS 권한 위생

최소 권한 IAM 자격증명 사용 - `/tools untrust aws`로 명시적 승인 강제, 환경변수에 자격증명 저장.

TRUST-ALL SAFELY

trust-all 안전 사용

Dev 와 test 환경 한정 사용- 특정 작업만 trust-all 후 `/tools reset`, 작업 전 데이터 백업, Kiro 동작 모니터링 필수.

Dev only

trust-all 사용 환경

Min IAM

AWS 최소 권한 원칙

`/tools reset`

trust-all 후 복원

Backup

작업 전 필수 조치

Thank you!

Choi, WooHyung / Prin. Solutions Architect / AWS Korea

whchoi@amazon.com

<https://linkedin.com/in/woohyungchoi>

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

